

API

vAmPI Scan | 2026-02-26 09:16:30

- **ID:** 14
- **URL:** http://vampi:5000
- : 7 (: 3, : 4)

AI

Mass Assignment ()

POST /users/v1/login | **Medium**

API allows sensitive field injection (e.g. is_admin)

Status: 200 with extra fields

AI

(DTO)		(Allow-list)
FastAPI	Pydantic	dict

Broken Function Level Authorization (BFLA)

GET /users/v1/_debug | **High**

Endpoint accessible by low-privilege user

Status: 200

AI

Allowing low-privilege users to access administrative functions.

(RBAC)

API

Broken Function Level Authorization (BFLA)

GET /users/v1 | High

Endpoint accessible by low-privilege user

Status: 200

AI

Allowing low-privilege users to access administrative functions.

(RBAC)

API

Excessive Data Exposure ()

GET /users/v1/_debug | Medium

Sensitive data fields exposed in response: password

Exposed fields: ['password']

AI

()

API

Schema

Broken Object Level Authorization (BOLA)

GET /users/v1/admin | High

Unauthorized access to object/resource belonging to others

Status: 200

AI

API ({id})

ID () UUID SQL user_id

Mass Assignment ()

POST /users/v1/register | Medium

API allows sensitive field injection (e.g. is_admin)

Status: 200 with extra fields

AI

(DTO) (Allow-list)

FastAPI Pydantic dict

Lack of Resources & Rate Limiting

POST /users/v1/login | Medium

API lacks Rate Limiting (API4:2023), allowing credential stuffing or DoS

Processed 15 burst requests with no 429 response

AI

API	(Brute-force)	(DoS)
API	(Throttling)	(Login)
Redis	API	(Kong, Nginx)

AI API